

GTOS Detailed Volume - Volume 14

Security Privacy Compliance

GTOS Enterprise Engineering Handbook - Final Edition 1.0

Source Chapters

- Security Architecture Introduction
- Zero Trust
- Authentication
- Authorization and ReBAC ABAC
- Tenant Isolation
- Delegation Security
- Secrets Management
- Cryptography
- Privacy and Purpose
- Data Residency
- Application Security
- API Security
- Event Security
- Workflow Security
- Database Security
- Portal and Browser Security
- Mobile Security
- AI Security
- Prompt Injection
- Browser and Code Sandboxing
- Fraud and Abuse
- Audit and Non-Repudiation
- Threat Modeling
- Incident Response
- Regulatory Evidence
- Volume 14 Conformance and Evidence Matrix

Security Architecture Introduction

Metadata	Value
Volume	14
Chapter ID	V14-00
Subject	SecurityArchitectureIntroduction
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Security Architecture Introduction.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
SecurityArchitectureIntroduction	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecurityArchitectureIntroductionVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecurityArchitectureIntroductionDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecurityArchitectureIntroductionEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecurityArchitectureIntroductionException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
SecurityArchitectureIntroduction {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateSecurityArchitectureIntroduction
- ValidateSecurityArchitectureIntroduction
- ApproveSecurityArchitectureIntroduction
- ActivateSecurityArchitectureIntroduction
- SuspendSecurityArchitectureIntroduction
- CorrectSecurityArchitectureIntroduction
- RetireSecurityArchitectureIntroduction

Reference Events:

- SecurityArchitectureIntroductionCreated
- SecurityArchitectureIntroductionValidated
- SecurityArchitectureIntroductionApproved
- SecurityArchitectureIntroductionActivated
- SecurityArchitectureIntroductionSuspended
- SecurityArchitectureIntroductionCorrected
- SecurityArchitectureIntroductionRetired

Reference queries:

- GetSecurityArchitectureIntroduction
- ListSecurityArchitectureIntroductionRecords
- GetSecurityArchitectureIntroductionTimeline
- GetSecurityArchitectureIntroductionEvidence
- GetSecurityArchitectureIntroductionDecisionPackage
- GetSecurityArchitectureIntroductionExceptions
- GetSecurityArchitectureIntroductionAuditTrail

Reference API surface:

```

POST /api/v1/securityarchitectureintroduction/commands
GET  /api/v1/securityarchitectureintroduction/{id}
GET  /api/v1/securityarchitectureintroduction/{id}/timeline
GET  /api/v1/securityarchitectureintroduction/{id}/evidence
GET  /api/v1/securityarchitectureintroduction/{id}/decisions
POST /api/v1/securityarchitectureintroduction/{id}/exceptions
POST /api/v1/securityarchitectureintroduction/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
securityarchitectureintroduction_aggregate	authoritative subject
securityarchitectureintroduction_version	immutable submitted, approved, issued, or signed versions
securityarchitectureintroduction_relationship	governed relationships
securityarchitectureintroduction_decision	binding Decisions and rationale
securityarchitectureintroduction_evidence_link	provenance and evidence relationships
securityarchitectureintroduction_event_outbox	transactional Event publication
securityarchitectureintroduction_idempotency	duplicate-write protection
securityarchitectureintroduction_exception	exception, claim, dispute, or hold
securityarchitectureintroduction_correction	correction and supersession lineage
securityarchitectureintroduction_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Security Architecture Introduction is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Zero Trust

Metadata	Value
Volume	14
Chapter ID	V14-01
Subject	ZeroTrust
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Zero Trust**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;

- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
ZeroTrust	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ZeroTrustVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ZeroTrustDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ZeroTrustEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ZeroTrustException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
ZeroTrust {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
    sourceVersionRefs[]
    knowledgeCutoff
    evidenceSetRef
}
```

```

policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateZeroTrust
- ValidateZeroTrust
- ApproveZeroTrust
- ActivateZeroTrust
- SuspendZeroTrust
- CorrectZeroTrust
- RetireZeroTrust

Reference Events:

- ZeroTrustCreated
- ZeroTrustValidated
- ZeroTrustApproved
- ZeroTrustActivated
- ZeroTrustSuspended
- ZeroTrustCorrected
- ZeroTrustRetired

Reference queries:

- GetZeroTrust
- ListZeroTrustRecords
- GetZeroTrustTimeline
- GetZeroTrustEvidence
- GetZeroTrustDecisionPackage
- GetZeroTrustExceptions
- GetZeroTrustAuditTrail

Reference API surface:

```

POST /api/v1/zerotrust/commands
GET  /api/v1/zerotrust/{id}
GET  /api/v1/zerotrust/{id}/timeline
GET  /api/v1/zerotrust/{id}/evidence
GET  /api/v1/zerotrust/{id}/decisions
POST /api/v1/zerotrust/{id}/exceptions
POST /api/v1/zerotrust/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]

```

```

G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
zerotrust_aggregate	authoritative subject
zerotrust_version	immutable submitted, approved, issued, or signed versions
zerotrust_relationship	governed relationships
zerotrust_decision	binding Decisions and rationale
zerotrust_evidence_link	provenance and evidence relationships
zerotrust_event_outbox	transactional Event publication
zerotrust_idempotency	duplicate-write protection
zerotrust_exception	exception, claim, dispute, or hold
zerotrust_correction	correction and supersession lineage
zerotrust_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Zero Trust is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW

Area	Classification
behavior proven in another repository-grounded chapter contradictory ownership or path claims	retain that chapter's evidence and classification CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Authentication

Metadata	Value
Volume	14
Chapter ID	V14-02
Subject	Authentication
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Authentication.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;

- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
Authentication	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthenticationException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
Authentication {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
    sourceVersionRefs[]
    knowledgeCutoff
    evidenceSetRef
}
```

```

policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAuthentication
- ValidateAuthentication
- ApproveAuthentication
- ActivateAuthentication
- SuspendAuthentication
- CorrectAuthentication
- RetireAuthentication

Reference Events:

- AuthenticationCreated
- AuthenticationValidated
- AuthenticationApproved
- AuthenticationActivated
- AuthenticationSuspended
- AuthenticationCorrected
- AuthenticationRetired

Reference queries:

- GetAuthentication
- ListAuthenticationRecords
- GetAuthenticationTimeline
- GetAuthenticationEvidence
- GetAuthenticationDecisionPackage
- GetAuthenticationExceptions
- GetAuthenticationAuditTrail

Reference API surface:

```

POST /api/v1/authentication/commands
GET  /api/v1/authentication/{id}
GET  /api/v1/authentication/{id}/timeline
GET  /api/v1/authentication/{id}/evidence
GET  /api/v1/authentication/{id}/decisions
POST /api/v1/authentication/{id}/exceptions
POST /api/v1/authentication/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]

```

```

G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
authentication_aggregate	authoritative subject
authentication_version	immutable submitted, approved, issued, or signed versions
authentication_relationship	governed relationships
authentication_decision	binding Decisions and rationale
authentication_evidence_link	provenance and evidence relationships
authentication_event_outbox	transactional Event publication
authentication_idempotency	duplicate-write protection
authentication_exception	exception, claim, dispute, or hold
authentication_correction	correction and supersession lineage
authentication_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Authentication is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW

Area	Classification
behavior proven in another repository-grounded chapter contradictory ownership or path claims	retain that chapter's evidence and classification CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED IMPLEMENTED_WITH_GAP	Executable source and relevant behavior were inspected. Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION REFERENCE_ARCHITECTURE PLANNED_NOT_IMPLEMENTED DOCUMENTATION_ONLY_CLAIM	Only part of the target capability is evidenced. Normative target behavior; no claim that it exists today. Explicitly planned but not evidenced as executable. Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION REQUIRES_REPOSITORY_REVIEW	Sources disagree and no final owner has been established. Necessary executable evidence has not yet been inspected.

Authorization and ReBAC ABAC

Metadata	Value
Volume	14
Chapter ID	V14-03
Subject	AuthorizationandReBACABAC
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Authorization and ReBAC ABAC**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AuthorizationandReBACABAC	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationandReBACABACVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationandReBACABACDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationandReBACABACEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuthorizationandReBACABACException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AuthorizationandReBACABAC {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAuthorizationandReBACABAC
- ValidateAuthorizationandReBACABAC
- ApproveAuthorizationandReBACABAC
- ActivateAuthorizationandReBACABAC
- SuspendAuthorizationandReBACABAC
- CorrectAuthorizationandReBACABAC
- RetireAuthorizationandReBACABAC

Reference Events:

- AuthorizationandReBACABACCreated
- AuthorizationandReBACABACValidated
- AuthorizationandReBACABACApproved
- AuthorizationandReBACABACActivated
- AuthorizationandReBACABACSuspended
- AuthorizationandReBACABACCorrected
- AuthorizationandReBACABACRetired

Reference queries:

- GetAuthorizationandReBACABAC
- ListAuthorizationandReBACABACRecords
- GetAuthorizationandReBACABACTimeline
- GetAuthorizationandReBACABACEvidence
- GetAuthorizationandReBACABACDecisionPackage
- GetAuthorizationandReBACABACExceptions
- GetAuthorizationandReBACABACAuditTrail

Reference API surface:

```

POST /api/v1/authorizationandrebacabac/commands
GET  /api/v1/authorizationandrebacabac/{id}
GET  /api/v1/authorizationandrebacabac/{id}/timeline
GET  /api/v1/authorizationandrebacabac/{id}/evidence
GET  /api/v1/authorizationandrebacabac/{id}/decisions
POST /api/v1/authorizationandrebacabac/{id}/exceptions
POST /api/v1/authorizationandrebacabac/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
authorizationandrebacabac_aggregate	authoritative subject
authorizationandrebacabac_version	immutable submitted, approved, issued, or signed versions
authorizationandrebacabac_relationship	governed relationships
authorizationandrebacabac_decision	binding Decisions and rationale
authorizationandrebacabac_evidence_link	provenance and evidence relationships
authorizationandrebacabac_event_outbox	transactional Event publication
authorizationandrebacabac_idempotency	duplicate-write protection
authorizationandrebacabac_exception	exception, claim, dispute, or hold
authorizationandrebacabac_correction	correction and supersession lineage
authorizationandrebacabac_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Authorization and ReBAC ABAC is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Tenant Isolation

Metadata	Value
Volume	14
Chapter ID	V14-04
Subject	TenantIsolation
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Tenant Isolation.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;

- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
TenantIsolation	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
TenantIsolationException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
TenantIsolation {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
    sourceVersionRefs[]
    knowledgeCutoff
    evidenceSetRef
}
```

```

policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateTenantIsolation
- ValidateTenantIsolation
- ApproveTenantIsolation
- ActivateTenantIsolation
- SuspendTenantIsolation
- CorrectTenantIsolation
- RetireTenantIsolation

Reference Events:

- TenantIsolationCreated
- TenantIsolationValidated
- TenantIsolationApproved
- TenantIsolationActivated
- TenantIsolationSuspended
- TenantIsolationCorrected
- TenantIsolationRetired

Reference queries:

- GetTenantIsolation
- ListTenantIsolationRecords
- GetTenantIsolationTimeline
- GetTenantIsolationEvidence
- GetTenantIsolationDecisionPackage
- GetTenantIsolationExceptions
- GetTenantIsolationAuditTrail

Reference API surface:

```

POST /api/v1/tenantisolation/commands
GET  /api/v1/tenantisolation/{id}
GET  /api/v1/tenantisolation/{id}/timeline
GET  /api/v1/tenantisolation/{id}/evidence
GET  /api/v1/tenantisolation/{id}/decisions
POST /api/v1/tenantisolation/{id}/exceptions
POST /api/v1/tenantisolation/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]

```

```

G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
tenantisolation_aggregate	authoritative subject
tenantisolation_version	immutable submitted, approved, issued, or signed versions
tenantisolation_relationship	governed relationships
tenantisolation_decision	binding Decisions and rationale
tenantisolation_evidence_link	provenance and evidence relationships
tenantisolation_event_outbox	transactional Event publication
tenantisolation_idempotency	duplicate-write protection
tenantisolation_exception	exception, claim, dispute, or hold
tenantisolation_correction	correction and supersession lineage
tenantisolation_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Tenant Isolation is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW

Area	Classification
behavior proven in another repository-grounded chapter contradictory ownership or path claims	retain that chapter's evidence and classification CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED IMPLEMENTED_WITH_GAP	Executable source and relevant behavior were inspected. Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION REFERENCE_ARCHITECTURE PLANNED_NOT_IMPLEMENTED DOCUMENTATION_ONLY_CLAIM	Only part of the target capability is evidenced. Normative target behavior; no claim that it exists today. Explicitly planned but not evidenced as executable. Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION REQUIRES_REPOSITORY_REVIEW	Sources disagree and no final owner has been established. Necessary executable evidence has not yet been inspected.

Delegation Security

Metadata	Value
Volume	14
Chapter ID	V14-05
Subject	DelegationSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Delegation Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
DelegationSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DelegationSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
DelegationSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateDelegationSecurity
- ValidateDelegationSecurity
- ApproveDelegationSecurity
- ActivateDelegationSecurity
- SuspendDelegationSecurity
- CorrectDelegationSecurity
- RetireDelegationSecurity

Reference Events:

- DelegationSecurityCreated
- DelegationSecurityValidated
- DelegationSecurityApproved
- DelegationSecurityActivated
- DelegationSecuritySuspended
- DelegationSecurityCorrected
- DelegationSecurityRetired

Reference queries:

- GetDelegationSecurity
- ListDelegationSecurityRecords
- GetDelegationSecurityTimeline
- GetDelegationSecurityEvidence
- GetDelegationSecurityDecisionPackage
- GetDelegationSecurityExceptions
- GetDelegationSecurityAuditTrail

Reference API surface:

```

POST /api/v1/delegationsecurity/commands
GET  /api/v1/delegationsecurity/{id}
GET  /api/v1/delegationsecurity/{id}/timeline
GET  /api/v1/delegationsecurity/{id}/evidence
GET  /api/v1/delegationsecurity/{id}/decisions
POST /api/v1/delegationsecurity/{id}/exceptions
POST /api/v1/delegationsecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
delegationsecurity_aggregate	authoritative subject
delegationsecurity_version	immutable submitted, approved, issued, or signed versions
delegationsecurity_relationship	governed relationships
delegationsecurity_decision	binding Decisions and rationale
delegationsecurity_evidence_link	provenance and evidence relationships
delegationsecurity_event_outbox	transactional Event publication
delegationsecurity_idempotency	duplicate-write protection
delegationsecurity_exception	exception, claim, dispute, or hold
delegationsecurity_correction	correction and supersession lineage
delegationsecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Delegation Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Secrets Management

Metadata	Value
Volume	14
Chapter ID	V14-06
Subject	SecretsManagement
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Secrets Management**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
SecretsManagement	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecretsManagementVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecretsManagementDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecretsManagementEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
SecretsManagementException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
SecretsManagement {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateSecretsManagement
- ValidateSecretsManagement
- ApproveSecretsManagement
- ActivateSecretsManagement
- SuspendSecretsManagement
- CorrectSecretsManagement
- RetireSecretsManagement

Reference Events:

- SecretsManagementCreated
- SecretsManagementValidated
- SecretsManagementApproved
- SecretsManagementActivated
- SecretsManagementSuspended
- SecretsManagementCorrected
- SecretsManagementRetired

Reference queries:

- GetSecretsManagement
- ListSecretsManagementRecords
- GetSecretsManagementTimeline
- GetSecretsManagementEvidence
- GetSecretsManagementDecisionPackage
- GetSecretsManagementExceptions
- GetSecretsManagementAuditTrail

Reference API surface:

```

POST /api/v1/secretsmanagement/commands
GET  /api/v1/secretsmanagement/{id}
GET  /api/v1/secretsmanagement/{id}/timeline
GET  /api/v1/secretsmanagement/{id}/evidence
GET  /api/v1/secretsmanagement/{id}/decisions
POST /api/v1/secretsmanagement/{id}/exceptions
POST /api/v1/secretsmanagement/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
secretsmanagement_aggregate	authoritative subject
secretsmanagement_version	immutable submitted, approved, issued, or signed versions
secretsmanagement_relationship	governed relationships
secretsmanagement_decision	binding Decisions and rationale
secretsmanagement_evidence_link	provenance and evidence relationships
secretsmanagement_event_outbox	transactional Event publication
secretsmanagement_idempotency	duplicate-write protection
secretsmanagement_exception	exception, claim, dispute, or hold
secretsmanagement_correction	correction and supersession lineage
secretsmanagement_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Secrets Management is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Cryptography

Metadata	Value
Volume	14
Chapter ID	V14-07
Subject	Cryptography
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Cryptography**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
Cryptography	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CryptographyVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CryptographyDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CryptographyEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
CryptographyException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
Cryptography {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateCryptography
- ValidateCryptography
- ApproveCryptography
- ActivateCryptography
- SuspendCryptography
- CorrectCryptography
- RetireCryptography

Reference Events:

- CryptographyCreated
- CryptographyValidated
- CryptographyApproved
- CryptographyActivated
- CryptographySuspended
- CryptographyCorrected
- CryptographyRetired

Reference queries:

- GetCryptography
- ListCryptographyRecords
- GetCryptographyTimeline
- GetCryptographyEvidence
- GetCryptographyDecisionPackage
- GetCryptographyExceptions
- GetCryptographyAuditTrail

Reference API surface:

```

POST /api/v1/cryptography/commands
GET  /api/v1/cryptography/{id}
GET  /api/v1/cryptography/{id}/timeline
GET  /api/v1/cryptography/{id}/evidence
GET  /api/v1/cryptography/{id}/decisions
POST /api/v1/cryptography/{id}/exceptions
POST /api/v1/cryptography/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
cryptography_aggregate	authoritative subject
cryptography_version	immutable submitted, approved, issued, or signed versions
cryptography_relationship	governed relationships
cryptography_decision	binding Decisions and rationale
cryptography_evidence_link	provenance and evidence relationships
cryptography_event_outbox	transactional Event publication
cryptography_idempotency	duplicate-write protection
cryptography_exception	exception, claim, dispute, or hold
cryptography_correction	correction and supersession lineage
cryptography_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Cryptography is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Privacy and Purpose

Metadata	Value
Volume	14
Chapter ID	V14-08
Subject	PrivacyandPurpose
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Privacy and Purpose**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
PrivacyandPurpose	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivacyandPurposeVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivacyandPurposeDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivacyandPurposeEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PrivacyandPurposeException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
PrivacyandPurpose {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreatePrivacyandPurpose
- ValidatePrivacyandPurpose
- ApprovePrivacyandPurpose
- ActivatePrivacyandPurpose
- SuspendPrivacyandPurpose
- CorrectPrivacyandPurpose
- RetirePrivacyandPurpose

Reference Events:

- PrivacyandPurposeCreated
- PrivacyandPurposeValidated
- PrivacyandPurposeApproved
- PrivacyandPurposeActivated
- PrivacyandPurposeSuspended
- PrivacyandPurposeCorrected
- PrivacyandPurposeRetired

Reference queries:

- GetPrivacyandPurpose
- ListPrivacyandPurposeRecords
- GetPrivacyandPurposeTimeline
- GetPrivacyandPurposeEvidence
- GetPrivacyandPurposeDecisionPackage
- GetPrivacyandPurposeExceptions
- GetPrivacyandPurposeAuditTrail

Reference API surface:

```

POST /api/v1/privacyandpurpose/commands
GET /api/v1/privacyandpurpose/{id}
GET /api/v1/privacyandpurpose/{id}/timeline
GET /api/v1/privacyandpurpose/{id}/evidence
GET /api/v1/privacyandpurpose/{id}/decisions
POST /api/v1/privacyandpurpose/{id}/exceptions
POST /api/v1/privacyandpurpose/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
privacyandpurpose_aggregate	authoritative subject
privacyandpurpose_version	immutable submitted, approved, issued, or signed versions
privacyandpurpose_relationship	governed relationships
privacyandpurpose_decision	binding Decisions and rationale
privacyandpurpose_evidence_link	provenance and evidence relationships
privacyandpurpose_event_outbox	transactional Event publication
privacyandpurpose_idempotency	duplicate-write protection
privacyandpurpose_exception	exception, claim, dispute, or hold
privacyandpurpose_correction	correction and supersession lineage
privacyandpurpose_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Privacy and Purpose is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Data Residency

Metadata	Value
Volume	14
Chapter ID	V14-09
Subject	DataResidency
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Data Residency**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
DataResidency	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DataResidencyVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DataResidencyDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DataResidencyEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DataResidencyException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
DataResidency {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateDataResidency
- ValidateDataResidency
- ApproveDataResidency
- ActivateDataResidency
- SuspendDataResidency
- CorrectDataResidency
- RetireDataResidency

Reference Events:

- DataResidencyCreated
- DataResidencyValidated
- DataResidencyApproved
- DataResidencyActivated
- DataResidencySuspended
- DataResidencyCorrected
- DataResidencyRetired

Reference queries:

- GetDataResidency
- ListDataResidencyRecords
- GetDataResidencyTimeline
- GetDataResidencyEvidence
- GetDataResidencyDecisionPackage
- GetDataResidencyExceptions
- GetDataResidencyAuditTrail

Reference API surface:

```

POST /api/v1/dataresidency/commands
GET  /api/v1/dataresidency/{id}
GET  /api/v1/dataresidency/{id}/timeline
GET  /api/v1/dataresidency/{id}/evidence
GET  /api/v1/dataresidency/{id}/decisions
POST /api/v1/dataresidency/{id}/exceptions
POST /api/v1/dataresidency/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
dataresidency_aggregate	authoritative subject
dataresidency_version	immutable submitted, approved, issued, or signed versions
dataresidency_relationship	governed relationships
dataresidency_decision	binding Decisions and rationale
dataresidency_evidence_link	provenance and evidence relationships
dataresidency_event_outbox	transactional Event publication
dataresidency_idempotency	duplicate-write protection
dataresidency_exception	exception, claim, dispute, or hold
dataresidency_correction	correction and supersession lineage
dataresidency_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Data Residency is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Application Security

Metadata	Value
Volume	14
Chapter ID	V14-10
Subject	ApplicationSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Application Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
ApplicationSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ApplicationSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ApplicationSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ApplicationSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ApplicationSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
ApplicationSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateApplicationSecurity
- ValidateApplicationSecurity
- ApproveApplicationSecurity
- ActivateApplicationSecurity
- SuspendApplicationSecurity
- CorrectApplicationSecurity
- RetireApplicationSecurity

Reference Events:

- ApplicationSecurityCreated
- ApplicationSecurityValidated
- ApplicationSecurityApproved
- ApplicationSecurityActivated
- ApplicationSecuritySuspended
- ApplicationSecurityCorrected
- ApplicationSecurityRetired

Reference queries:

- GetApplicationSecurity
- ListApplicationSecurityRecords
- GetApplicationSecurityTimeline
- GetApplicationSecurityEvidence
- GetApplicationSecurityDecisionPackage
- GetApplicationSecurityExceptions
- GetApplicationSecurityAuditTrail

Reference API surface:

```

POST /api/v1/applicationsecurity/commands
GET  /api/v1/applicationsecurity/{id}
GET  /api/v1/applicationsecurity/{id}/timeline
GET  /api/v1/applicationsecurity/{id}/evidence
GET  /api/v1/applicationsecurity/{id}/decisions
POST /api/v1/applicationsecurity/{id}/exceptions
POST /api/v1/applicationsecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
applicationsecurity_aggregate	authoritative subject
applicationsecurity_version	immutable submitted, approved, issued, or signed versions
applicationsecurity_relationship	governed relationships
applicationsecurity_decision	binding Decisions and rationale
applicationsecurity_evidence_link	provenance and evidence relationships
applicationsecurity_event_outbox	transactional Event publication
applicationsecurity_idempotency	duplicate-write protection
applicationsecurity_exception	exception, claim, dispute, or hold
applicationsecurity_correction	correction and supersession lineage
applicationsecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Application Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

API Security

Metadata	Value
Volume	14
Chapter ID	V14-11
Subject	APISecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for API Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
APISecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
APISecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
APISecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
APISecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
APISecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
APISecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAPISecurity
- ValidateAPISecurity
- ApproveAPISecurity
- ActivateAPISecurity
- SuspendAPISecurity
- CorrectAPISecurity
- RetireAPISecurity

Reference Events:

- APISecurityCreated
- APISecurityValidated
- APISecurityApproved
- APISecurityActivated
- APISecuritySuspended
- APISecurityCorrected
- APISecurityRetired

Reference queries:

- GetAPISecurity
- ListAPISecurityRecords
- GetAPISecurityTimeline
- GetAPISecurityEvidence
- GetAPISecurityDecisionPackage
- GetAPISecurityExceptions
- GetAPISecurityAuditTrail

Reference API surface:

```

POST /api/v1/apisecurity/commands
GET  /api/v1/apisecurity/{id}
GET  /api/v1/apisecurity/{id}/timeline
GET  /api/v1/apisecurity/{id}/evidence
GET  /api/v1/apisecurity/{id}/decisions
POST /api/v1/apisecurity/{id}/exceptions
POST /api/v1/apisecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
apisecurity_aggregate	authoritative subject
apisecurity_version	immutable submitted, approved, issued, or signed versions
apisecurity_relationship	governed relationships
apisecurity_decision	binding Decisions and rationale
apisecurity_evidence_link	provenance and evidence relationships
apisecurity_event_outbox	transactional Event publication
apisecurity_idempotency	duplicate-write protection
apisecurity_exception	exception, claim, dispute, or hold
apisecurity_correction	correction and supersession lineage
apisecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- API Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Event Security

Metadata	Value
Volume	14
Chapter ID	V14-12
Subject	EventSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Event Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
EventSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
EventSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
EventSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
EventSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
EventSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
EventSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateEventSecurity
- ValidateEventSecurity
- ApproveEventSecurity
- ActivateEventSecurity
- SuspendEventSecurity
- CorrectEventSecurity
- RetireEventSecurity

Reference Events:

- EventSecurityCreated
- EventSecurityValidated
- EventSecurityApproved
- EventSecurityActivated
- EventSecuritySuspended
- EventSecurityCorrected
- EventSecurityRetired

Reference queries:

- GetEventSecurity
- ListEventSecurityRecords
- GetEventSecurityTimeline
- GetEventSecurityEvidence
- GetEventSecurityDecisionPackage
- GetEventSecurityExceptions
- GetEventSecurityAuditTrail

Reference API surface:

```

POST /api/v1/eventsecurity/commands
GET  /api/v1/eventsecurity/{id}
GET  /api/v1/eventsecurity/{id}/timeline
GET  /api/v1/eventsecurity/{id}/evidence
GET  /api/v1/eventsecurity/{id}/decisions
POST /api/v1/eventsecurity/{id}/exceptions
POST /api/v1/eventsecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
eventsecurity_aggregate	authoritative subject
eventsecurity_version	immutable submitted, approved, issued, or signed versions
eventsecurity_relationship	governed relationships
eventsecurity_decision	binding Decisions and rationale
eventsecurity_evidence_link	provenance and evidence relationships
eventsecurity_event_outbox	transactional Event publication
eventsecurity_idempotency	duplicate-write protection
eventsecurity_exception	exception, claim, dispute, or hold
eventsecurity_correction	correction and supersession lineage
eventsecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Event Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Workflow Security

Metadata	Value
Volume	14
Chapter ID	V14-13
Subject	WorkflowSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Workflow Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
WorkflowSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
WorkflowSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
WorkflowSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
WorkflowSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
WorkflowSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
WorkflowSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateWorkflowSecurity
- ValidateWorkflowSecurity
- ApproveWorkflowSecurity
- ActivateWorkflowSecurity
- SuspendWorkflowSecurity
- CorrectWorkflowSecurity
- RetireWorkflowSecurity

Reference Events:

- WorkflowSecurityCreated
- WorkflowSecurityValidated
- WorkflowSecurityApproved
- WorkflowSecurityActivated
- WorkflowSecuritySuspended
- WorkflowSecurityCorrected
- WorkflowSecurityRetired

Reference queries:

- GetWorkflowSecurity
- ListWorkflowSecurityRecords
- GetWorkflowSecurityTimeline
- GetWorkflowSecurityEvidence
- GetWorkflowSecurityDecisionPackage
- GetWorkflowSecurityExceptions
- GetWorkflowSecurityAuditTrail

Reference API surface:

```

POST /api/v1/workflowsecurity/commands
GET  /api/v1/workflowsecurity/{id}
GET  /api/v1/workflowsecurity/{id}/timeline
GET  /api/v1/workflowsecurity/{id}/evidence
GET  /api/v1/workflowsecurity/{id}/decisions
POST /api/v1/workflowsecurity/{id}/exceptions
POST /api/v1/workflowsecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
workflowsecurity_aggregate	authoritative subject
workflowsecurity_version	immutable submitted, approved, issued, or signed versions
workflowsecurity_relationship	governed relationships
workflowsecurity_decision	binding Decisions and rationale
workflowsecurity_evidence_link	provenance and evidence relationships
workflowsecurity_event_outbox	transactional Event publication
workflowsecurity_idempotency	duplicate-write protection
workflowsecurity_exception	exception, claim, dispute, or hold
workflowsecurity_correction	correction and supersession lineage
workflowsecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Workflow Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Database Security

Metadata	Value
Volume	14
Chapter ID	V14-14
Subject	DatabaseSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Database Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
DatabaseSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DatabaseSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DatabaseSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DatabaseSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
DatabaseSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
DatabaseSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateDatabaseSecurity
- ValidateDatabaseSecurity
- ApproveDatabaseSecurity
- ActivateDatabaseSecurity
- SuspendDatabaseSecurity
- CorrectDatabaseSecurity
- RetireDatabaseSecurity

Reference Events:

- DatabaseSecurityCreated
- DatabaseSecurityValidated
- DatabaseSecurityApproved
- DatabaseSecurityActivated
- DatabaseSecuritySuspended
- DatabaseSecurityCorrected
- DatabaseSecurityRetired

Reference queries:

- GetDatabaseSecurity
- ListDatabaseSecurityRecords
- GetDatabaseSecurityTimeline
- GetDatabaseSecurityEvidence
- GetDatabaseSecurityDecisionPackage
- GetDatabaseSecurityExceptions
- GetDatabaseSecurityAuditTrail

Reference API surface:

```

POST /api/v1/databasesecurity/commands
GET  /api/v1/databasesecurity/{id}
GET  /api/v1/databasesecurity/{id}/timeline
GET  /api/v1/databasesecurity/{id}/evidence
GET  /api/v1/databasesecurity/{id}/decisions
POST /api/v1/databasesecurity/{id}/exceptions
POST /api/v1/databasesecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
databasesecurity_aggregate	authoritative subject
databasesecurity_version	immutable submitted, approved, issued, or signed versions
databasesecurity_relationship	governed relationships
databasesecurity_decision	binding Decisions and rationale
databasesecurity_evidence_link	provenance and evidence relationships
databasesecurity_event_outbox	transactional Event publication
databasesecurity_idempotency	duplicate-write protection
databasesecurity_exception	exception, claim, dispute, or hold
databasesecurity_correction	correction and supersession lineage
databasesecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Database Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Portal and Browser Security

Metadata	Value
Volume	14
Chapter ID	V14-15
Subject	PortalandBrowserSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Portal and Browser Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
PortlandBrowserSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PortlandBrowserSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PortlandBrowserSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PortlandBrowserSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PortlandBrowserSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
PortlandBrowserSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreatePortalandBrowserSecurity
- ValidatePortalandBrowserSecurity
- ApprovePortalandBrowserSecurity
- ActivatePortalandBrowserSecurity
- SuspendPortalandBrowserSecurity
- CorrectPortalandBrowserSecurity
- RetirePortalandBrowserSecurity

Reference Events:

- PortalandBrowserSecurityCreated
- PortalandBrowserSecurityValidated
- PortalandBrowserSecurityApproved
- PortalandBrowserSecurityActivated
- PortalandBrowserSecuritySuspended
- PortalandBrowserSecurityCorrected
- PortalandBrowserSecurityRetired

Reference queries:

- GetPortalandBrowserSecurity
- ListPortalandBrowserSecurityRecords
- GetPortalandBrowserSecurityTimeline
- GetPortalandBrowserSecurityEvidence
- GetPortalandBrowserSecurityDecisionPackage
- GetPortalandBrowserSecurityExceptions
- GetPortalandBrowserSecurityAuditTrail

Reference API surface:

```

POST /api/v1/portalandbrowsersecurity/commands
GET  /api/v1/portalandbrowsersecurity/{id}
GET  /api/v1/portalandbrowsersecurity/{id}/timeline
GET  /api/v1/portalandbrowsersecurity/{id}/evidence
GET  /api/v1/portalandbrowsersecurity/{id}/decisions
POST /api/v1/portalandbrowsersecurity/{id}/exceptions
POST /api/v1/portalandbrowsersecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
portalandbrowsersecurity_aggregate	authoritative subject
portalandbrowsersecurity_version	immutable submitted, approved, issued, or signed versions
portalandbrowsersecurity_relationship	governed relationships
portalandbrowsersecurity_decision	binding Decisions and rationale
portalandbrowsersecurity_evidence_link	provenance and evidence relationships
portalandbrowsersecurity_event_outbox	transactional Event publication
portalandbrowsersecurity_idempotency	duplicate-write protection
portalandbrowsersecurity_exception	exception, claim, dispute, or hold
portalandbrowsersecurity_correction	correction and supersession lineage
portalandbrowsersecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Portal and Browser Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Mobile Security

Metadata	Value
Volume	14
Chapter ID	V14-16
Subject	MobileSecurity
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Mobile Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
MobileSecurity	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MobileSecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MobileSecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MobileSecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
MobileSecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
MobileSecurity {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateMobileSecurity
- ValidateMobileSecurity
- ApproveMobileSecurity
- ActivateMobileSecurity
- SuspendMobileSecurity
- CorrectMobileSecurity
- RetireMobileSecurity

Reference Events:

- MobileSecurityCreated
- MobileSecurityValidated
- MobileSecurityApproved
- MobileSecurityActivated
- MobileSecuritySuspended
- MobileSecurityCorrected
- MobileSecurityRetired

Reference queries:

- GetMobileSecurity
- ListMobileSecurityRecords
- GetMobileSecurityTimeline
- GetMobileSecurityEvidence
- GetMobileSecurityDecisionPackage
- GetMobileSecurityExceptions
- GetMobileSecurityAuditTrail

Reference API surface:

```

POST /api/v1/mobilesecurity/commands
GET  /api/v1/mobilesecurity/{id}
GET  /api/v1/mobilesecurity/{id}/timeline
GET  /api/v1/mobilesecurity/{id}/evidence
GET  /api/v1/mobilesecurity/{id}/decisions
POST /api/v1/mobilesecurity/{id}/exceptions
POST /api/v1/mobilesecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
mobilesecurity_aggregate	authoritative subject
mobilesecurity_version	immutable submitted, approved, issued, or signed versions
mobilesecurity_relationship	governed relationships
mobilesecurity_decision	binding Decisions and rationale
mobilesecurity_evidence_link	provenance and evidence relationships
mobilesecurity_event_outbox	transactional Event publication
mobilesecurity_idempotency	duplicate-write protection
mobilesecurity_exception	exception, claim, dispute, or hold
mobilesecurity_correction	correction and supersession lineage
mobilesecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Mobile Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

AI Security

Metadata	Value
Volume	14
Chapter ID	V14-17
Subject	AI Security
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for AI Security**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AI Security	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AI SecurityVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AI SecurityDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AI SecurityEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AI SecurityException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AI Security {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAISecurity
- ValidateAISecurity
- ApproveAISecurity
- ActivateAISecurity
- SuspendAISecurity
- CorrectAISecurity
- RetireAISecurity

Reference Events:

- AISecurityCreated
- AISecurityValidated
- AISecurityApproved
- AISecurityActivated
- AISecuritySuspended
- AISecurityCorrected
- AISecurityRetired

Reference queries:

- GetAISecurity
- ListAISecurityRecords
- GetAISecurityTimeline
- GetAISecurityEvidence
- GetAISecurityDecisionPackage
- GetAISecurityExceptions
- GetAISecurityAuditTrail

Reference API surface:

```

POST /api/v1/aisecurity/commands
GET  /api/v1/aisecurity/{id}
GET  /api/v1/aisecurity/{id}/timeline
GET  /api/v1/aisecurity/{id}/evidence
GET  /api/v1/aisecurity/{id}/decisions
POST /api/v1/aisecurity/{id}/exceptions
POST /api/v1/aisecurity/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
aisecurity_aggregate	authoritative subject
aisecurity_version	immutable submitted, approved, issued, or signed versions
aisecurity_relationship	governed relationships
aisecurity_decision	binding Decisions and rationale
aisecurity_evidence_link	provenance and evidence relationships
aisecurity_event_outbox	transactional Event publication
aisecurity_idempotency	duplicate-write protection
aisecurity_exception	exception, claim, dispute, or hold
aisecurity_correction	correction and supersession lineage
aisecurity_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- AI Security is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Prompt Injection

Metadata	Value
Volume	14
Chapter ID	V14-18
Subject	PromptInjection
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Prompt Injection**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
PromptInjection	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PromptInjectionVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PromptInjectionDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PromptInjectionEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
PromptInjectionException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
PromptInjection {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreatePromptInjection
- ValidatePromptInjection
- ApprovePromptInjection
- ActivatePromptInjection
- SuspendPromptInjection
- CorrectPromptInjection
- RetirePromptInjection

Reference Events:

- PromptInjectionCreated
- PromptInjectionValidated
- PromptInjectionApproved
- PromptInjectionActivated
- PromptInjectionSuspended
- PromptInjectionCorrected
- PromptInjectionRetired

Reference queries:

- GetPromptInjection
- ListPromptInjectionRecords
- GetPromptInjectionTimeline
- GetPromptInjectionEvidence
- GetPromptInjectionDecisionPackage
- GetPromptInjectionExceptions
- GetPromptInjectionAuditTrail

Reference API surface:

```

POST /api/v1/promptinjection/commands
GET  /api/v1/promptinjection/{id}
GET  /api/v1/promptinjection/{id}/timeline
GET  /api/v1/promptinjection/{id}/evidence
GET  /api/v1/promptinjection/{id}/decisions
POST /api/v1/promptinjection/{id}/exceptions
POST /api/v1/promptinjection/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
promptinjection_aggregate	authoritative subject
promptinjection_version	immutable submitted, approved, issued, or signed versions
promptinjection_relationship	governed relationships
promptinjection_decision	binding Decisions and rationale
promptinjection_evidence_link	provenance and evidence relationships
promptinjection_event_outbox	transactional Event publication
promptinjection_idempotency	duplicate-write protection
promptinjection_exception	exception, claim, dispute, or hold
promptinjection_correction	correction and supersession lineage
promptinjection_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Prompt Injection is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Browser and Code Sandboxing

Metadata	Value
Volume	14
Chapter ID	V14-19
Subject	BrowserandCodeSandboxing
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Browser and Code Sandboxing**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
BrowserandCodeSandboxing	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
BrowserandCodeSandboxingVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
BrowserandCodeSandboxingDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
BrowserandCodeSandboxingEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
BrowserandCodeSandboxingException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
BrowserandCodeSandboxing {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateBrowserandCodeSandboxing
- ValidateBrowserandCodeSandboxing
- ApproveBrowserandCodeSandboxing
- ActivateBrowserandCodeSandboxing
- SuspendBrowserandCodeSandboxing
- CorrectBrowserandCodeSandboxing
- RetireBrowserandCodeSandboxing

Reference Events:

- BrowserandCodeSandboxingCreated
- BrowserandCodeSandboxingValidated
- BrowserandCodeSandboxingApproved
- BrowserandCodeSandboxingActivated
- BrowserandCodeSandboxingSuspended
- BrowserandCodeSandboxingCorrected
- BrowserandCodeSandboxingRetired

Reference queries:

- GetBrowserandCodeSandboxing
- ListBrowserandCodeSandboxingRecords
- GetBrowserandCodeSandboxingTimeline
- GetBrowserandCodeSandboxingEvidence
- GetBrowserandCodeSandboxingDecisionPackage
- GetBrowserandCodeSandboxingExceptions
- GetBrowserandCodeSandboxingAuditTrail

Reference API surface:

```

POST /api/v1/browserandcodesandboxing/commands
GET  /api/v1/browserandcodesandboxing/{id}
GET  /api/v1/browserandcodesandboxing/{id}/timeline
GET  /api/v1/browserandcodesandboxing/{id}/evidence
GET  /api/v1/browserandcodesandboxing/{id}/decisions
POST /api/v1/browserandcodesandboxing/{id}/exceptions
POST /api/v1/browserandcodesandboxing/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
browserandcodesandboxing_aggregate	authoritative subject
browserandcodesandboxing_version	immutable submitted, approved, issued, or signed versions
browserandcodesandboxing_relationship	governed relationships
browserandcodesandboxing_decision	binding Decisions and rationale
browserandcodesandboxing_evidence_link	provenance and evidence relationships
browserandcodesandboxing_event_outbox	transactional Event publication
browserandcodesandboxing_idempotency	duplicate-write protection
browserandcodesandboxing_exception	exception, claim, dispute, or hold
browserandcodesandboxing_correction	correction and supersession lineage
browserandcodesandboxing_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Browser and Code Sandboxing is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Fraud and Abuse

Metadata	Value
Volume	14
Chapter ID	V14-20
Subject	FraudandAbuse
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Fraud and Abuse.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;

- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
FraudandAbuse	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
FraudandAbuseVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
FraudandAbuseDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
FraudandAbuseEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
FraudandAbuseException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
FraudandAbuse {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
    sourceVersionRefs[]
    knowledgeCutoff
    evidenceSetRef
}
```

```

policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateFraudandAbuse
- ValidateFraudandAbuse
- ApproveFraudandAbuse
- ActivateFraudandAbuse
- SuspendFraudandAbuse
- CorrectFraudandAbuse
- RetireFraudandAbuse

Reference Events:

- FraudandAbuseCreated
- FraudandAbuseValidated
- FraudandAbuseApproved
- FraudandAbuseActivated
- FraudandAbuseSuspended
- FraudandAbuseCorrected
- FraudandAbuseRetired

Reference queries:

- GetFraudandAbuse
- ListFraudandAbuseRecords
- GetFraudandAbuseTimeline
- GetFraudandAbuseEvidence
- GetFraudandAbuseDecisionPackage
- GetFraudandAbuseExceptions
- GetFraudandAbuseAuditTrail

Reference API surface:

```

POST /api/v1/fraudandabuse/commands
GET  /api/v1/fraudandabuse/{id}
GET  /api/v1/fraudandabuse/{id}/timeline
GET  /api/v1/fraudandabuse/{id}/evidence
GET  /api/v1/fraudandabuse/{id}/decisions
POST /api/v1/fraudandabuse/{id}/exceptions
POST /api/v1/fraudandabuse/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]

```

```

G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
fraudandabuse_aggregate	authoritative subject
fraudandabuse_version	immutable submitted, approved, issued, or signed versions
fraudandabuse_relationship	governed relationships
fraudandabuse_decision	binding Decisions and rationale
fraudandabuse_evidence_link	provenance and evidence relationships
fraudandabuse_event_outbox	transactional Event publication
fraudandabuse_idempotency	duplicate-write protection
fraudandabuse_exception	exception, claim, dispute, or hold
fraudandabuse_correction	correction and supersession lineage
fraudandabuse_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Fraud and Abuse is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW

Area	Classification
behavior proven in another repository-grounded chapter contradictory ownership or path claims	retain that chapter's evidence and classification CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED IMPLEMENTED_WITH_GAP	Executable source and relevant behavior were inspected. Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION REFERENCE_ARCHITECTURE PLANNED_NOT_IMPLEMENTED DOCUMENTATION_ONLY_CLAIM	Only part of the target capability is evidenced. Normative target behavior; no claim that it exists today. Explicitly planned but not evidenced as executable. Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION REQUIRES_REPOSITORY_REVIEW	Sources disagree and no final owner has been established. Necessary executable evidence has not yet been inspected.

Audit and Non-Repudiation

Metadata	Value
Volume	14
Chapter ID	V14-21
Subject	AuditandNon-Repudiation
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Audit and Non-Repudiation.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
AuditandNon-Repudiation	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuditandNon-RepudiationVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuditandNon-RepudiationDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuditandNon-RepudiationEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
AuditandNon-RepudiationException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
AuditandNon-Repudiation {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateAuditandNon-Repudiation
- ValidateAuditandNon-Repudiation
- ApproveAuditandNon-Repudiation
- ActivateAuditandNon-Repudiation
- SuspendAuditandNon-Repudiation
- CorrectAuditandNon-Repudiation
- RetireAuditandNon-Repudiation

Reference Events:

- AuditandNon-RepudiationCreated
- AuditandNon-RepudiationValidated
- AuditandNon-RepudiationApproved
- AuditandNon-RepudiationActivated
- AuditandNon-RepudiationSuspended
- AuditandNon-RepudiationCorrected
- AuditandNon-RepudiationRetired

Reference queries:

- GetAuditandNon-Repudiation
- ListAuditandNon-RepudiationRecords
- GetAuditandNon-RepudiationTimeline
- GetAuditandNon-RepudiationEvidence
- GetAuditandNon-RepudiationDecisionPackage
- GetAuditandNon-RepudiationExceptions
- GetAuditandNon-RepudiationAuditTrail

Reference API surface:

```

POST /api/v1/auditandnon_repudiation/commands
GET  /api/v1/auditandnon_repudiation/{id}
GET  /api/v1/auditandnon_repudiation/{id}/timeline
GET  /api/v1/auditandnon_repudiation/{id}/evidence
GET  /api/v1/auditandnon_repudiation/{id}/decisions
POST /api/v1/auditandnon_repudiation/{id}/exceptions
POST /api/v1/auditandnon_repudiation/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
auditandnon_repudiation_aggregate	authoritative subject
auditandnon_repudiation_version	immutable submitted, approved, issued, or signed versions
auditandnon_repudiation_relationship	governed relationships
auditandnon_repudiation_decision	binding Decisions and rationale
auditandnon_repudiation_evidence_link	provenance and evidence relationships
auditandnon_repudiation_event_outbox	transactional Event publication
auditandnon_repudiation_idempotency	duplicate-write protection
auditandnon_repudiation_exception	exception, claim, dispute, or hold
auditandnon_repudiation_correction	correction and supersession lineage
auditandnon_repudiation_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Audit and Non-Repudiation is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Threat Modeling

Metadata	Value
Volume	14
Chapter ID	V14-22
Subject	ThreatModeling
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Threat Modeling**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
ThreatModeling	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ThreatModelingVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ThreatModelingDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ThreatModelingEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
ThreatModelingException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
ThreatModeling {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateThreatModeling
- ValidateThreatModeling
- ApproveThreatModeling
- ActivateThreatModeling
- SuspendThreatModeling
- CorrectThreatModeling
- RetireThreatModeling

Reference Events:

- ThreatModelingCreated
- ThreatModelingValidated
- ThreatModelingApproved
- ThreatModelingActivated
- ThreatModelingSuspended
- ThreatModelingCorrected
- ThreatModelingRetired

Reference queries:

- GetThreatModeling
- ListThreatModelingRecords
- GetThreatModelingTimeline
- GetThreatModelingEvidence
- GetThreatModelingDecisionPackage
- GetThreatModelingExceptions
- GetThreatModelingAuditTrail

Reference API surface:

```

POST /api/v1/threatmodeling/commands
GET  /api/v1/threatmodeling/{id}
GET  /api/v1/threatmodeling/{id}/timeline
GET  /api/v1/threatmodeling/{id}/evidence
GET  /api/v1/threatmodeling/{id}/decisions
POST /api/v1/threatmodeling/{id}/exceptions
POST /api/v1/threatmodeling/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
threatmodeling_aggregate	authoritative subject
threatmodeling_version	immutable submitted, approved, issued, or signed versions
threatmodeling_relationship	governed relationships
threatmodeling_decision	binding Decisions and rationale
threatmodeling_evidence_link	provenance and evidence relationships
threatmodeling_event_outbox	transactional Event publication
threatmodeling_idempotency	duplicate-write protection
threatmodeling_exception	exception, claim, dispute, or hold
threatmodeling_correction	correction and supersession lineage
threatmodeling_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Threat Modeling is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Incident Response

Metadata	Value
Volume	14
Chapter ID	V14-23
Subject	IncidentResponse
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Incident Response**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
IncidentResponse	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IncidentResponseVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IncidentResponseDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IncidentResponseEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
IncidentResponseException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
IncidentResponse {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateIncidentResponse
- ValidateIncidentResponse
- ApproveIncidentResponse
- ActivateIncidentResponse
- SuspendIncidentResponse
- CorrectIncidentResponse
- RetireIncidentResponse

Reference Events:

- IncidentResponseCreated
- IncidentResponseValidated
- IncidentResponseApproved
- IncidentResponseActivated
- IncidentResponseSuspended
- IncidentResponseCorrected
- IncidentResponseRetired

Reference queries:

- GetIncidentResponse
- ListIncidentResponseRecords
- GetIncidentResponseTimeline
- GetIncidentResponseEvidence
- GetIncidentResponseDecisionPackage
- GetIncidentResponseExceptions
- GetIncidentResponseAuditTrail

Reference API surface:

```

POST /api/v1/incidentresponse/commands
GET  /api/v1/incidentresponse/{id}
GET  /api/v1/incidentresponse/{id}/timeline
GET  /api/v1/incidentresponse/{id}/evidence
GET  /api/v1/incidentresponse/{id}/decisions
POST /api/v1/incidentresponse/{id}/exceptions
POST /api/v1/incidentresponse/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
incidentresponse_aggregate	authoritative subject
incidentresponse_version	immutable submitted, approved, issued, or signed versions
incidentresponse_relationship	governed relationships
incidentresponse_decision	binding Decisions and rationale
incidentresponse_evidence_link	provenance and evidence relationships
incidentresponse_event_outbox	transactional Event publication
incidentresponse_idempotency	duplicate-write protection
incidentresponse_exception	exception, claim, dispute, or hold
incidentresponse_correction	correction and supersession lineage
incidentresponse_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Incident Response is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Regulatory Evidence

Metadata	Value
Volume	14
Chapter ID	V14-24
Subject	RegulatoryEvidence
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **define the target architecture, implementation standard, evidence, security, reliability, operations, tests, migration and conformance requirements for Regulatory Evidence**.

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome

- ≠ Observation
- ≠ Claim
- ≠ derived Perspective
- ≠ Prediction
- ≠ Recommendation
- ≠ authorized Decision
- ≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;
- direct cross-Domain database writes;

- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
RegulatoryEvidence	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
RegulatoryEvidenceVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
RegulatoryEvidenceDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
RegulatoryEvidenceEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
RegulatoryEvidenceException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
RegulatoryEvidence {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage
- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
 - require exact expected version where concurrent change matters;
 - record actor, represented principal, mandate, Policy, reason, and Evidence;
 - use an idempotency key for retried writes;
 - publish a completed-fact Event after durable state change;
 - expose Outcome Unknown for unresolved external completion;
 - preserve original and corrected states in historical reconstruction.
-

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
    decisionType
    subjectRef
}
```

```

sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateRegulatoryEvidence
- ValidateRegulatoryEvidence
- ApproveRegulatoryEvidence
- ActivateRegulatoryEvidence
- SuspendRegulatoryEvidence
- CorrectRegulatoryEvidence
- RetireRegulatoryEvidence

Reference Events:

- RegulatoryEvidenceCreated
- RegulatoryEvidenceValidated
- RegulatoryEvidenceApproved
- RegulatoryEvidenceActivated
- RegulatoryEvidenceSuspended
- RegulatoryEvidenceCorrected
- RegulatoryEvidenceRetired

Reference queries:

- GetRegulatoryEvidence
- ListRegulatoryEvidenceRecords
- GetRegulatoryEvidenceTimeline
- GetRegulatoryEvidenceEvidence
- GetRegulatoryEvidenceDecisionPackage
- GetRegulatoryEvidenceExceptions
- GetRegulatoryEvidenceAuditTrail

Reference API surface:

```

POST /api/v1/regulatoryevidence/commands
GET  /api/v1/regulatoryevidence/{id}
GET  /api/v1/regulatoryevidence/{id}/timeline
GET  /api/v1/regulatoryevidence/{id}/evidence
GET  /api/v1/regulatoryevidence/{id}/decisions
POST /api/v1/regulatoryevidence/{id}/exceptions
POST /api/v1/regulatoryevidence/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B
C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]

```

```

F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
regulatoryevidence_aggregate	authoritative subject
regulatoryevidence_version	immutable submitted, approved, issued, or signed versions
regulatoryevidence_relationship	governed relationships
regulatoryevidence_decision	binding Decisions and rationale
regulatoryevidence_evidence_link	provenance and evidence relationships
regulatoryevidence_event_outbox	transactional Event publication
regulatoryevidence_idempotency	duplicate-write protection
regulatoryevidence_exception	exception, claim, dispute, or hold
regulatoryevidence_correction	correction and supersession lineage
regulatoryevidence_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions
- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
stale-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- Regulatory Evidence is part of the target GTOS handbook scope.
- Exact implementation, configuration, deployment, tests and runtime evidence require repository and environment inspection.
- Plans and infrastructure manifests are classified separately from observed runtime behavior.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.

Volume 14 Conformance and Evidence Matrix

Metadata	Value
Volume	14
Chapter ID	V14-SYNTH
Subject	Volume14ConformanceMatrix
Status	Generated First-Draft Architecture Skeleton - Domain-Specific Expansion Required
Content maturity	TEMPLATE_DERIVED_REFERENCE_SKELETON unless repository citations prove otherwise
Default implementation classification	REFERENCE_ARCHITECTURE / REQUIRES_REPOSITORY_REVIEW
Accountable owner	Security and Privacy Council
Evidence rule	No implementation claim without inspected executable evidence
Repository	chinair88-prog/allinb2c

1. Executive Orientation

This chapter defines how GTOS shall **trace every requirement in Volume 14 to owner, repository source, configuration, deployment, runtime evidence, tests, runbooks, exceptions and review status.**

The specification separates reality, observations, knowledge, Decisions, Intent, execution, and outcomes. A component name, database row, UI label, AI answer, or workflow state does not acquire authority merely because it is visible or technically convenient.

Reality or external outcome
≠ Observation
≠ Claim
≠ derived Perspective
≠ Prediction
≠ Recommendation
≠ authorized Decision
≠ execution Intent

1.1 Accountable ownership

The accountable owner is **Security and Privacy Council**. Supporting applications, shared infrastructure, integration adapters, analytics, and AI coordinate or present the capability but shall not silently own its authoritative propositions.

1.2 Scope

- create and identify the subject
- validate evidence and policy
- make authorized Decisions
- execute typed Commands
- publish completed-fact Events
- query current and historical perspectives
- correct and reconcile outcomes

1.3 Non-goals

- treating a registered Gradle module, catalog record, README, frontend route, migration plan, or generated report as proof of end-to-end implementation;

- direct cross-Domain database writes;
- generic status values that combine lifecycle, approval, provider, document, payment, dispute, and correction state;
- silent replacement of history;
- AI-created authority or fabricated external outcomes.

2. Ubiquitous Language and Subject Model

Subject	Required interpretation
Volume14ConformanceMatrix	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
Volume14ConformanceMatrixVersion	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
Volume14ConformanceMatrixDecision	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
Volume14ConformanceMatrixEvidenceSet	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit
Volume14ConformanceMatrixException	Independent identified subject, governed subordinate entity, or qualified perspective; ownership must be explicit

Reference aggregate:

```
Volume14ConformanceMatrix {
  subjectId
  tenantId
  organizationContext
  sourceIdentityRefs[]
  sourceVersionRefs[]
  lifecycleState
  relationshipRefs[]
  decisionRefs[]
  intentRefs[]
  evidenceSetRef
  knowledgeCutoff
  policyRefs[]
  authorityRef
  jurisdictionRefs[]
  createdAt
  effectiveAt
  updatedAt
  version
  correctionOf?
  correlationId
}
```

2.1 Core invariants

- Stable identity precedes relationship, state, and cross-system correlation.
- Effective time and recorded time remain distinct where business truth changes over time.
- Recommendation, Decision, Intent, execution, and outcome are separate concepts.
- No Portal, report, search index, cache, workflow, or AI Agent becomes a shadow owner of Domain truth.
- Binding submitted, approved, issued, accepted, or signed versions are immutable.
- Corrections append governed facts and preserve the original record.
- External authority and provider outcomes retain their source and qualification.
- Tenant and represented-principal context come from trusted authentication and mandate evaluation.
- Retried writes are idempotent and concurrency guarded.
- Outcome Unknown is explicit and reconciled before risky duplicate execution.

2.2 Required standards

- stable identifiers
- typed contracts
- immutable binding versions
- transactional outbox
- idempotent Commands
- explicit Outcome Unknown
- correction lineage

- machine-verifiable conformance

3. Actors, Roles, and Authority

A conformant design distinguishes:

- the natural person acting;
- the service or AI identity invoking a Tool;
- the organization or principal represented;
- the role or relationship granting context;
- the mandate or delegation granting action authority;
- the Policy and jurisdiction limiting the action;
- the reviewer or approver responsible for a binding Decision.

Authority is evaluated at action time. Authentication alone does not grant business authority. Cached permissions and browser-supplied tenant headers are insufficient for high-impact actions.

4. Lifecycle and State Model

State	Semantics
PROPOSED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
VALIDATION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
APPROVAL_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
ACTIVE	Distinct governed condition with entry, exit, timeout, correction and authority semantics
SUSPENDED	Distinct governed condition with entry, exit, timeout, correction and authority semantics
CORRECTION_PENDING	Distinct governed condition with entry, exit, timeout, correction and authority semantics
RETIRED	Distinct governed condition with entry, exit, timeout, correction and authority semantics

```
stateDiagram-v2
    [*] --> PROPOSED
    PROPOSED --> VALIDATION_PENDING
    VALIDATION_PENDING --> APPROVAL_PENDING
    APPROVAL_PENDING --> ACTIVE
    ACTIVE --> SUSPENDED
    SUSPENDED --> CORRECTION_PENDING
    CORRECTION_PENDING --> RETIRED
```

The diagram is a primary reading path. Real implementations may add parallel review, amendment, appeal, timeout, suspension, partial completion, reconciliation, correction, and terminal failure without collapsing their meaning.

4.1 Transition rules

- transition through a typed, authorized Command;
- require exact expected version where concurrent change matters;
- record actor, represented principal, mandate, Policy, reason, and Evidence;
- use an idempotency key for retried writes;
- publish a completed-fact Event after durable state change;
- expose Outcome Unknown for unresolved external completion;
- preserve original and corrected states in historical reconstruction.

5. Decision, Evidence, and Knowledge Cutoff

Reference Decision:

```
Decision {
    decisionId
```

```

decisionType
subjectRef
sourceVersionRefs[]
knowledgeCutoff
evidenceSetRef
policyVersionRefs[]
recommendationRefs[]
principalId
representedOrganizationId
mandateRef
rationale
outcome
decidedAt
effectiveAt
correctionOf?
}

```

Evidence records identify issuer or observer, subject, version, observed time, received time, effective interval, integrity, confidence, qualification, contradiction, correction, retention, residency, and access class. A recommendation may assist the Decision but cannot promote itself to the Decision.

6. Commands, Events, Queries, and Contracts

Reference Commands:

- CreateVolume14ConformanceMatrix
- ValidateVolume14ConformanceMatrix
- ApproveVolume14ConformanceMatrix
- ActivateVolume14ConformanceMatrix
- SuspendVolume14ConformanceMatrix
- CorrectVolume14ConformanceMatrix
- RetireVolume14ConformanceMatrix

Reference Events:

- Volume14ConformanceMatrixCreated
- Volume14ConformanceMatrixValidated
- Volume14ConformanceMatrixApproved
- Volume14ConformanceMatrixActivated
- Volume14ConformanceMatrixSuspended
- Volume14ConformanceMatrixCorrected
- Volume14ConformanceMatrixRetired

Reference queries:

- GetVolume14ConformanceMatrix
- ListVolume14ConformanceMatrixRecords
- GetVolume14ConformanceMatrixTimeline
- GetVolume14ConformanceMatrixEvidence
- GetVolume14ConformanceMatrixDecisionPackage
- GetVolume14ConformanceMatrixExceptions
- GetVolume14ConformanceMatrixAuditTrail

Reference API surface:

```

POST /api/v1/volume14conformancematrix/commands
GET  /api/v1/volume14conformancematrix/{id}
GET  /api/v1/volume14conformancematrix/{id}/timeline
GET  /api/v1/volume14conformancematrix/{id}/evidence
GET  /api/v1/volume14conformancematrix/{id}/decisions
POST /api/v1/volume14conformancematrix/{id}/exceptions
POST /api/v1/volume14conformancematrix/{id}/corrections

```

These endpoints are reference contracts, not claims that exact routes exist.

7. Workflow, Failure, and Compensation

flowchart TD

```

A[Validate identity version and authority] --> B[Collect required evidence]
B --> C{Policy and evidence gates pass?}
C -- No --> D[Open exception or request correction]
D --> B

```

```

C -- Yes --> E[Record Decision or execution Intent]
E --> F[Execute Domain command or external request]
F --> G{Outcome known?}
G -- Success --> H[Record fact and publish Event]
G -- Failure --> I[Record failure and compensation options]
G -- Unknown --> J[Enter Outcome Unknown]
J --> K[Query source or wait for verified callback]
K --> G
H --> L[Update projections and downstream workflow]

```

Representative failure modes:

- stale or wrong source version
- duplicate submission or replay
- external timeout after possible success
- contradictory source observations
- lost Event after committed state
- approval or mandate revoked during execution
- downstream action before a mandatory gate
- partial completion across multiple subjects
- evidence later retracted or corrected
- tenant, facility, channel or jurisdiction mismatch

Recovery shall query the authoritative source before duplicate execution, preserve partial success, use compensating Intent rather than destructive rewrite, publish corrections, quarantine high-impact ambiguity, and record affected downstream subjects.

8. Data and Persistence Architecture

Reference table families:

Table family	Purpose
volumel4conformancematrix_aggregate	authoritative subject
volumel4conformancematrix_version	immutable submitted, approved, issued, or signed versions
volumel4conformancematrix_relationship	governed relationships
volumel4conformancematrix_decision	binding Decisions and rationale
volumel4conformancematrix_evidence_link	provenance and evidence relationships
volumel4conformancematrix_event_outbox	transactional Event publication
volumel4conformancematrix_idempotency	duplicate-write protection
volumel4conformancematrix_exception	exception, claim, dispute, or hold
volumel4conformancematrix_correction	correction and supersession lineage
volumel4conformancematrix_audit	privileged action evidence

The owning service controls schema and migration. Cross-Domain references use stable identifiers or contracts. Analytics, reports, caches, search, and vector indexes remain projections. Backup, restore, retention, legal hold, privacy, residency, and decommissioning requirements are explicit.

9. Portal and Experience Requirements

- Primary participant Portal: initiate, review exact versions, supply evidence, and respond to required actions.
- Operator Portal: inspect exceptions, correlation, source responses, retries, compensation, and downstream impact.
- Executive or oversight view: consume governed metrics without becoming a source of Domain truth.

Every Portal displays exact version, owner, state, freshness, required action, and uncertainty. It supports loading, empty, partial, stale, denied, error, timeout, and Outcome Unknown states; accessibility; locale, currency, unit, date, and RTL/LTR correctness; evidence audit; safe retry; and correction history.

10. AI Participation and Tool Governance

Permitted AI tasks:

- extract and classify evidence
- detect anomalies and missing fields
- summarize timelines and contradictions

- recommend next actions with sources and uncertainty

AI shall not own Domain records, grant itself authority, suppress contradictions, silently edit approved versions, fabricate external outcomes, or execute high-impact actions outside typed Tools, policy, approval, idempotency, sandbox, and outcome observation.

Every Agent Run records source context, prompt/model/tool versions, structured output, confidence and limitations, Policy result, approval, Tool calls, provider responses, final outcome, and recovery actions.

11. Security, Privacy, and Trust Boundaries

- least privilege and separation of duties
- tenant, organization, facility, channel and jurisdiction isolation
- integrity protection for binding evidence
- verified external callbacks and anti-replay controls

Additional controls include secret isolation, callback signature verification, audit of privileged action, emergency-access review, sensitive-data minimization, purpose limitation, and threat models for impersonation, tampering, replay, confused deputy, fraud, prompt injection, and exfiltration.

12. Reliability, SLOs, and Operations

SLI	Reference objective
authoritative read availability	99.9% monthly unless a stricter tier applies
acknowledged Command durability	no acknowledged write may be silently lost
Event publication	99.9% within five minutes after committed fact
duplicate prevention	100% for same tenant, Command class, and idempotency key
binding Decision audit completeness	100%
state-state detection	bounded by business deadline

Dashboards and runbooks cover backlog, error budget, dependency failure, retry budget, DLQ, workflow stall, provider outage, reconciliation, capacity, backup/restore, release/rollback, incident command, and post-incident correction.

13. Testing and Continuous Conformance

- aggregate invariant and transition tests
- authorization, delegation, separation-of-duties and tenant-isolation tests
- idempotency and optimistic-concurrency tests
- database migration, key, constraint and rollback tests
- contract, outbox/inbox, duplicate, replay and DLQ tests
- workflow restart, timeout and compensation tests
- Portal E2E tests for success, partial, stale, denied, error and Outcome Unknown states
- accessibility, locale, currency, unit and RTL/LTR tests
- security adversarial, fraud and data-exfiltration tests
- AI evaluation, prompt-injection, policy-bypass and unauthorized-tool tests
- historical reconstruction, correction and audit-completeness tests
- performance, capacity, recovery and operational exercise tests

Release evidence links each invariant and control to the test, environment, input data, result, owner, and artifact proving it. Generated test counts never replace semantic coverage.

14. Repository Review Boundary

- This chapter is a repository-review specification. Exact executable implementation has not been inspected for every target behavior.
- Registered modules, catalog entries, README claims, frontend contracts, or plans are not proof of complete implementation.

Area	Classification
target aggregate, API, tables, state and workflow in this chapter	REFERENCE_ARCHITECTURE
registered module or catalog claim	DOCUMENTATION_ONLY_CLAIM until source inspection
uninspected integration	REQUIRES_REPOSITORY_REVIEW
behavior proven in another repository-grounded chapter	retain that chapter's evidence and classification
contradictory ownership or path claims	CONFLICT_REQUIRES_CANONICALIZATION

No statement upgrades implementation status merely because a file, directory, module name, frontend contract, database entry, plan, or report exists.

15. Worked Conformance Scenario

An authorized principal initiates a Command against an exact subject version. The service validates identity, tenant, mandate, Policy, Evidence, and idempotency. It records the state transition and outbox entry atomically. If an external dependency participates, timeout produces Outcome Unknown; reconciliation queries the source or waits for a verified callback instead of repeating the action blindly.

Portals show source, freshness, version, required action, and uncertainty. AI may extract, compare, summarize, detect anomalies, and recommend through typed Tools, but cannot own the subject or fabricate success. Later correction appends new facts, identifies affected projections and workflows, and preserves the historical Decision context.

16. Conformance Checklist

- ☐ stable identity and proposition ownership are explicit;
- ☐ authority and mandate are evaluated at action time;
- ☐ state, Recommendation, Decision, Intent, execution, and outcome remain distinct;
- ☐ Commands are typed, authorized, idempotent, and version guarded;
- ☐ Events describe completed facts;
- ☐ Evidence includes provenance, time, integrity, qualification, and correction;
- ☐ external outcomes retain their authority source;
- ☐ Portals show freshness and uncertainty;
- ☐ AI is bounded by typed Tools, Policy, approval, and outcome observation;
- ☐ security, tenant, facility, channel, and jurisdiction boundaries are enforced;
- ☐ Outcome Unknown and reconciliation exist where needed;
- ☐ corrections preserve history;
- ☐ tests prove invariants and recovery;
- ☐ implementation status is not upgraded without executable evidence.

17. Status Vocabulary

Status	Meaning
VERIFIED_IMPLEMENTED	Executable source and relevant behavior were inspected.
IMPLEMENTED_WITH_GAP	Executable behavior exists with a material governance or completeness gap.
PARTIAL_IMPLEMENTATION	Only part of the target capability is evidenced.
REFERENCE_ARCHITECTURE	Normative target behavior; no claim that it exists today.
PLANNED_NOT_IMPLEMENTED	Explicitly planned but not evidenced as executable.
DOCUMENTATION_ONLY_CLAIM	Documentation or client contract claims behavior without verified backend evidence.
CONFLICT_REQUIRES_CANONICALIZATION	Sources disagree and no final owner has been established.
REQUIRES_REPOSITORY_REVIEW	Necessary executable evidence has not yet been inspected.